DECLARACIÓN DE APLICABILIDAD (SOA)

Código Documento: SOA-2026-TEC

Dominio Evaluado: Tecnológico

Fecha Actualización: 2026-09-22

Estado: Borrador

Resumen: Justificación de la inclusión o exclusión de los controles del Anexo A (ISO/IEC 27001) para el dominio seleccionado.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.1	**Dispositivos de punto final del usuario** La información almacenada en, procesada por o accesible a través de dispositivos de punto final del usuario debe protegerse.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.2	**Derechos de acceso privilegiado** La asignación y el uso de derechos de acceso privilegiado deben restringirse y gestionarse.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (8) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.
8.3	**Restricción de acceso a la información** El acceso a la información y otros activos asociados debe restringirse de acuerdo con la política de control de acceso establecida y específica del tema.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (8) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.4	**Acceso al código fuente** El acceso de lectura y escritura al código fuente, las herramientas de desarrollo y las bibliotecas de software debe gestionarse adecuadamente.	**NO**	NO APLICABLE. La organización no custodia ni mantiene código fuente propio. Los desarrollos a la medida sobre el ERP son propiedad del proveedor y residen en su repositorio, según el contrato CT-2024-08. El riesgo asociado se gestiona a través de los controles 5.20 y 8.30. Verificado en la auditoría integral del 13/04/2026.
8.5	**Autenticación segura** Se deben implementar tecnologías y procedimientos de autenticación segura basados en restricciones de acceso a la información y la política de control de acceso específica del tema.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (8) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.
8.6	**Gestión de la capacidad** El uso de los recursos debe monitorearse y ajustarse en línea con los requisitos de capacidad actuales y esperados.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.7	**Protección contra malware** La protección contra malware debe implementarse y respaldarse mediante la concienciación adecuada del usuario.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.8	**Gestión de vulnerabilidades técnicas** Debe obtenerse información sobre las vulnerabilidades técnicas de los sistemas de información en uso, evaluarse la exposición de la organización a dichas vulnerabilidades y tomarse las medidas apropiadas.	**SÍ**	APLICABLE. Control de mayor criticidad junto con 5.15: zona Extrema (25). Sustenta la detección oportuna de debilidades técnicas en el ERP y en la infraestructura expuesta a internet.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.9	**Gestión de la configuración** Las configuraciones, incluidas las configuraciones de seguridad, del hardware, software, servicios y redes deben establecerse, documentarse, implementarse, monitorearse y revisarse.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.10	**Eliminación de información** La información almacenada en sistemas de información, dispositivos o en cualquier otro medio de almacenamiento debe eliminarse cuando ya no sea necesaria.	**SÍ**	APLICABLE. Riesgo Alto (9). Exigido por el principio de temporalidad del tratamiento de datos personales (Ley 1581 y Decreto 1377).
8.11	**Enmascaramiento de datos** El enmascaramiento de datos debe usarse de acuerdo con la política de control de acceso específica del tema de la organización y otros requisitos específicos del tema relacionados, y los requisitos del negocio, teniendo en cuenta la legislación aplicable.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (6) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.
8.12	**Prevención de fuga de datos** Las medidas de prevención de fuga de datos deben aplicarse a los sistemas, redes y otros dispositivos que procesan, almacenan o transmiten información sensible.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (6) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.13	**Copia de seguridad de la información** Las copias de seguridad de la información, el software y los sistemas deben mantenerse y probarse regularmente de acuerdo con la política de copia de seguridad acordada específica del tema.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.14	**Redundancia de las instalaciones de procesamiento de información** Las instalaciones de procesamiento de información deben implementarse con redundancia suficiente para cumplir los requisitos de disponibilidad.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.15	**Registro de actividad (logging)** Deben producirse, almacenarse, protegerse y analizarse registros que registren actividades, excepciones, fallas y otros eventos relevantes.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.16	**Actividades de monitoreo** Las redes, los sistemas y las aplicaciones deben monitorearse para detectar comportamientos anómalos y deben tomarse las acciones apropiadas para evaluar los posibles incidentes de seguridad de la información.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (8) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.17	**Sincronización del reloj** Los relojes de los sistemas de procesamiento de información utilizados por la organización deben sincronizarse con fuentes de tiempo de referencia aprobadas.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.18	**Uso de programas de utilidades privilegiados** El uso de programas de utilidades que puedan ser capaces de anular los controles del sistema y la aplicación debe restringirse y controlarse estrictamente.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.19	**Instalación de software en sistemas operativos** Deben implementarse procedimientos y medidas para gestionar de forma segura la instalación de software en los sistemas operativos.	**SÍ**	APLICABLE. Riesgo Alto (12). El control se refuerza con la estrategia de evitación: retiro de privilegios de administrador local a todos los usuarios.
8.20	**Seguridad de redes** Las redes y los dispositivos de red deben protegerse, gestionarse y controlarse para proteger la información en los sistemas y aplicaciones.	**SÍ**	APLICABLE. Riesgo Alto (12). Toda la operación depende de la red interna y del enlace con el proveedor del ERP.
8.21	**Seguridad de los servicios de red** Los mecanismos de seguridad, los niveles de servicio y los requisitos de servicio de todos los servicios de red deben identificarse, implementarse y monitorearse.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.22	**Segregación de redes** Los grupos de servicios de información, usuarios y sistemas de información deben segregarse en las redes de la organización.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (8) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.
8.23	**Filtrado web** El acceso a sitios web externos debe gestionarse para reducir la exposición a contenido malicioso.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (6) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.
8.24	**Uso de criptografía** Deben definirse e implementarse reglas para el uso efectivo de la criptografía, incluida la gestión de claves criptográficas.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.25	**Ciclo de vida de desarrollo seguro** Deben establecerse e implementarse reglas para el desarrollo seguro de software y sistemas.	**NO**	NO APLICABLE. La organización no ejecuta actividades de desarrollo de software. El ciclo de vida de desarrollo seguro es obligación contractual del proveedor del ERP y su cumplimiento se verifica mediante el control 8.30. Exclusión aprobada en el comité del 07/09/2026.
8.26	**Requisitos de seguridad de las aplicaciones** Los requisitos de seguridad de la información deben identificarse, especificarse y aprobarse cuando se desarrollan o adquieren aplicaciones.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.27	**Principios de arquitectura de sistemas seguros** Los principios para diseñar sistemas seguros deben establecerse, documentarse, mantenerse y aplicarse a cualquier actividad de desarrollo de sistemas de información.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.28	**Codificación segura** Los principios de codificación segura deben aplicarse al desarrollo de software.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (8) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.
8.29	**Pruebas de seguridad en desarrollo y aceptación** Los procesos de prueba de seguridad deben definirse e implementarse en el ciclo de vida del desarrollo.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.30	**Desarrollo subcontratado** La organización debe dirigir, monitorear y revisar las actividades relacionadas con el desarrollo de sistemas subcontratados.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.
8.31	**Separación de los entornos de desarrollo, prueba y producción** Los entornos de desarrollo, prueba y producción deben separarse y asegurarse.	**NO**	NO APLICABLE. La organización no mantiene entornos de desarrollo ni de prueba propios. Los aloja y administra el proveedor del ERP en instancias separadas de producción, condición verificada en la auditoría integral y exigible por el control 5.22. Exclusión aprobada en el comité del 07/09/2026.
8.32	**Gestión de cambios** Los cambios en las instalaciones de procesamiento de información y los sistemas de información deben estar sujetos a procedimientos de gestión de cambios.	**SÍ**	APLICABLE. Riesgo Alto (9). Un cambio no controlado en el ERP ya provoco dos días sin facturación en marzo de 2026.
8.33	**Información de prueba** La información de prueba debe seleccionarse, protegerse y gestionarse adecuadamente.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Moderada (6) por debilidades verificadas en la auditoría integral. Se mantiene en el alcance con tratamiento de reducción progresiva.

CÓDIGO	CONTROL	APLICA	JUSTIFICACIÓN
8.34	**Protección de los sistemas de información durante las pruebas de auditoría** Las pruebas de auditoría y otras actividades de aseguramiento que implican la evaluación de los sistemas operativos deben planificarse y acordarse entre el evaluador y la dirección apropiada.	**SÍ**	APLICABLE. La apreciación de riesgos del 13/04/2026 lo ubicó en zona Baja (2): el control opera y se verifico su evidencia. Se mantiene en el alcance para sostener el nivel alcanzado.